Simulasi Serangan & Pertahanan Siber pada Sistem IoT PiRoTech

Anggota Kelompok:

1. Muhammad Ganabitz Dzikri J0404241157 - Lead Team
2. Aisha Aulia Darmawan J0404241007 - Red Team
3. Kesya Khoerunisa Putri Suryaman J0404241058 - Red Team
4. Gyanrendra Nayaran Wiratmaja J0404241172 - Blue Team

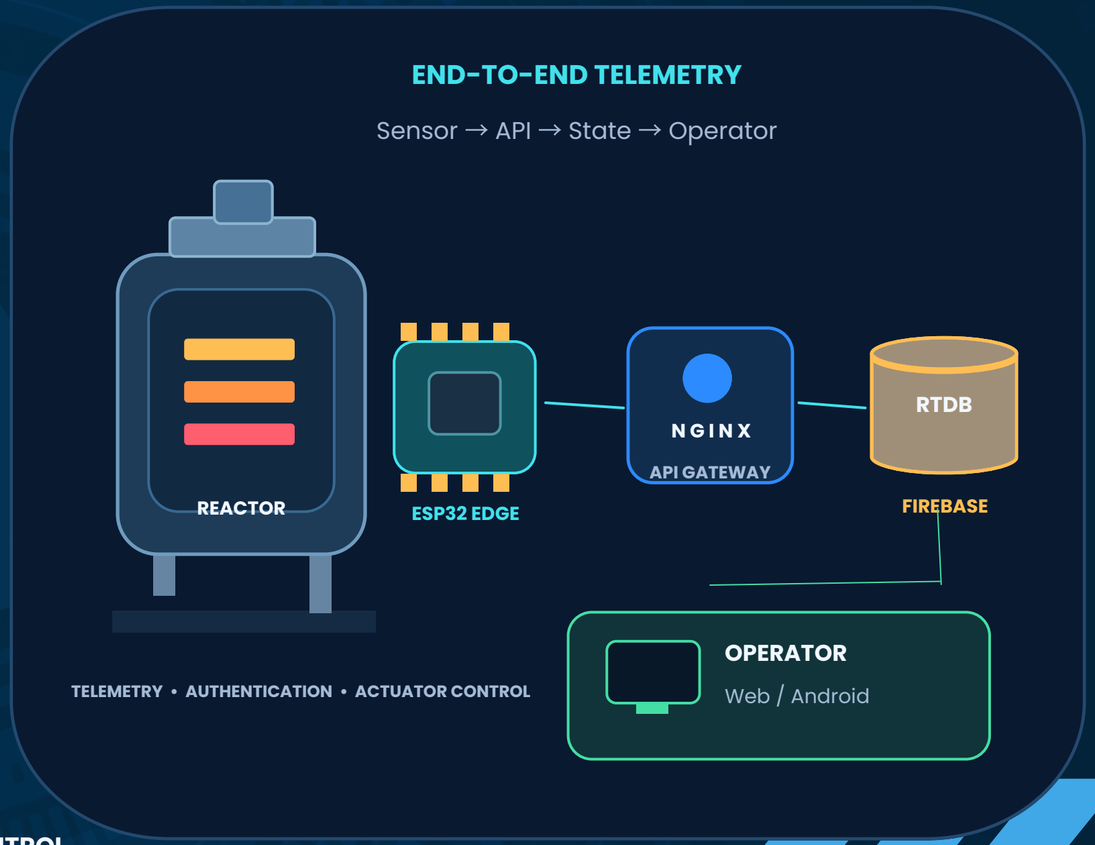
PiRoTech IoT Smart Pyrolysis

Sistem pemantauan telemetri reaktor pirolisis termal limbah plastik berbasis IoT.

Memantau suhu 100°C–200°C dan mengendalikan buzzer keselamatan secara real-time.

TEMPERATUR
100–200°C

MODE SISTEM
Real-time IoT



SYSTEM PILLARS

EDGE TELEMETRY
ESP32 • Sensor • Buzzer

SECURE API LAYER
Nginx • REST API • Firebase

WEB & MOBILE CONTROL
Dashboard • Android • Logs

SECURITY FOCUS | Sensitive-route protection • Telemetry flood control • Emergency actuator integrity

Pemetaan Komponen Asli ke Target Node

Sistem Asli / Produksi Riil (Real-World System)

Reaktor Pirolisis
(Edge Hardware)

- ESP32
- Termokopel MAX6675
- Piezo Buzzer & Relay Heater

Internet

Server Cloud

- Node.js / Express
- Firebase Admin SDK
- REST API

Aplikasi Android
(Teknisi)

- Kotlin / Flutter
- HTTP Request
- Monitoring & Control

Mapped to Isolated Lab Environment (Subnet 192.168.14.0/24)

Replika Lab / Jaringan Lab (Subnet 192.168.14.0/24)

Attacker Node (192.168.14.100)

- CyberOps VM
- cURL / Bash Loop
- Python Scripts
- Fuzzing / DoS

Monitoring Node (192.168.14.50)

- Security Onion
- (Zeek, Suricata, Kibana/Wazuh)
- CloudWatch / Datadog
- Port Mirroring

Mirror Traffic

Switch
(192.168.14.0/24)

Defender / Target Node (192.168.14.5)

Nginx API Gateway (Port 80)

- Reverse Proxy
- Limit Rate (limit_req)
- Security Headers
- Block /api/debug/
- Protect Buzzer Status

Node.js + Firebase Replica (Port 3000)

- Express.js (server.js)
- REST API Engine
- Auth & Business Logic
- Firebase RTDB / JSON State

Python ESP32 Simulator

- Generate Suhu 100°C–200°C
- Status Buzzer
- HTTP POST/PUT
- (esp32_simulator.py)

Client / User (Ops)

- Web Dashboaad (React/Tailwind)
- Android App (Kotlin/Flutter)
- cURL / HTTP Request
- Monitor & Control Buzzer

Tabel Perbandingan & Pemetaan Menyeluruh Komponen Sistem

Komponen	Sistem Asli (Produksi Riil)	Target Node / Replika Lab	Tech Stack Asli	Tech Stack Replika Lab	Peran & Alur Data
Edge Hardware Reaktor	Reaktor Pirolisis Fisik	IoT Simulator Process (Node Internal / Localhost)	ESP32, MAX6675, Buzzer, Relay Heater	Python (esp32_simulator.py), requests, time, JSON	Mengemulasikan pembacaan suhu (100°C–200°C) dan status buzzer, lalu mengirim via HTTP ke API Gateway.
Perimeter Network / Pintu Masuk API	Defender Node (192.168.14.5:80)	Cloudflare / AWS API Gateway Hardware Firewall Nginx 1.28.x Ubuntu 24.04 LTS	Nginx, Ubuntu Server	Limit_req, security headers	Limit_req, security headers Menyaring serangan, blokir rute /api/debug/ & proteksi buzzer, teruskan ke port 3000.
Aplikasi Backend / Business Logic	Internal Service (127.0.0.1:3000)	Node.js + Express (Cloud Server)	Node.js / Express.js Firebase Admin SDK	REST API Engine .env (Local Environment)	Memproses data telemetri, autentikasi pengguna, catat status buzzer.
Database & Penyimpanan State	Firebase (Cloud)	Firebase Replica / In-Memory State	Firebase RTDB (GCP)	sensor_data.json & buzzer.json	Menyimpan histori suhu dan status darurat secara instan.
Klien Pengguna (Operator)	Aplikasi Android (Teknisi)	Client Simulation (Web / Android)	Kotlin / Flutter, React / Tailwind	HTTP Request, Browser / cURL	Memantau suhu reaktor dan kirim instruksi kontrol buzzer.
Entitas Penyerang Siber	—	Attacker Node (192.168.14.100)	—	cURL, Bash Loop, Python Scripts	Menguji celah keamanan (curi env key, bypass auth, flooding DoS).
Sistem Monitoring Keamanan	—	Monitoring Node (192.168.14.50)	—	Security Onion, CloudWatch, Port Mirroring	Pantau lalu lintas subnet 192.168.14.0/24 dan catat anomali keamanan.

Narasi Konsep Replika Lab

1 Kenapa Perlu Replika Lab?
Reaktor pirolisis beroperasi pada 100°C–200°C dan terhubung langsung ke Firebase di cloud. Membawa reaktor fisik ke lab berisiko dan tidak memungkinkan. Oleh karena itu, seluruh ekosistem dipetakan ke subnet lab tertutup (192.168.14.0/24).

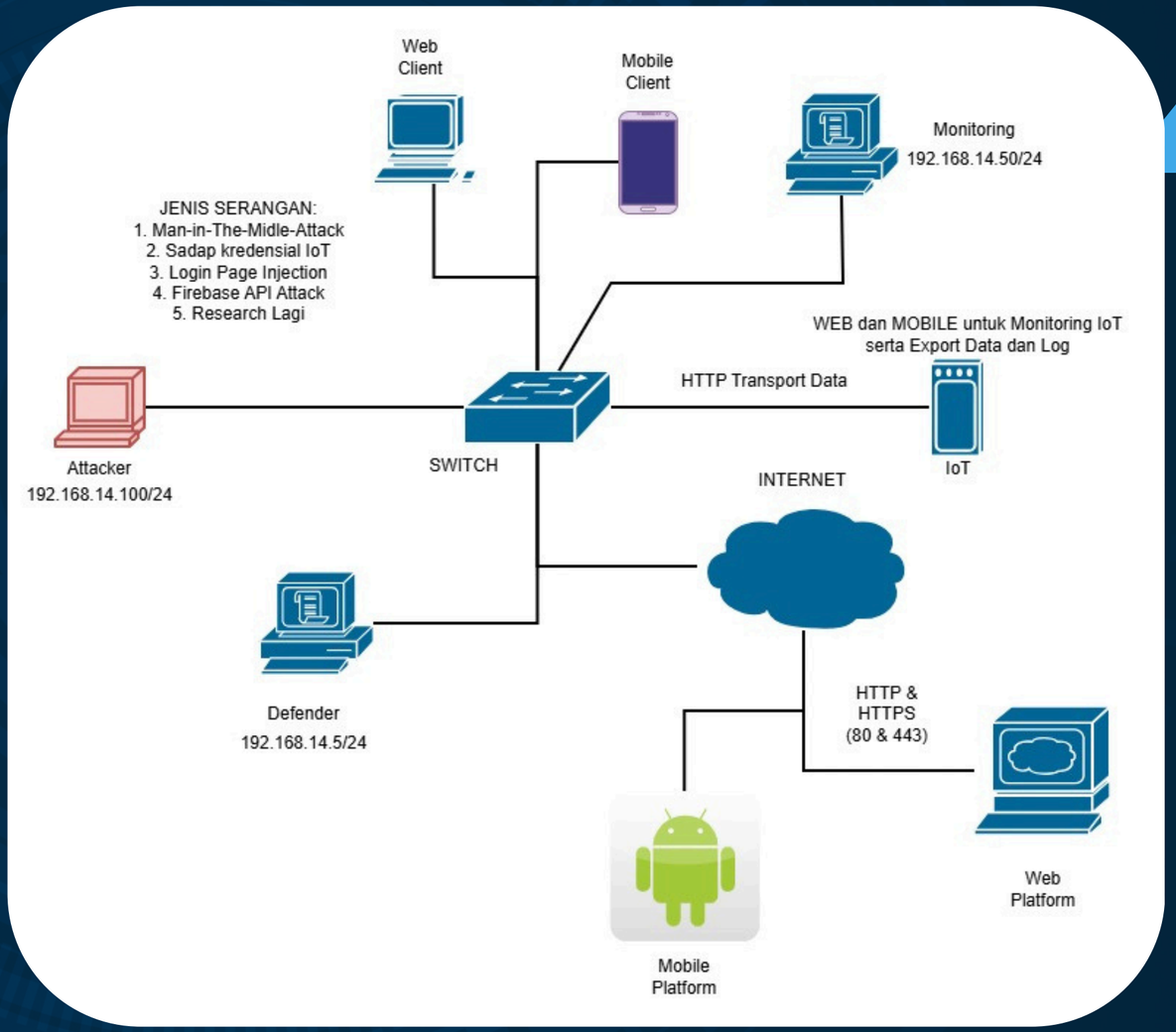
2 Sisi Pengirim Data (Edge)
ESP32 fisik digantikan oleh simulator Python yang menghasilkan kenaikan dan penurunan suhu pirolisis identik dengan kondisi lapangan.

3 Sisi Target Pertahanan (Target Node)
Nginx sebagai gerbang terdepan (port 80) di Ubuntu Server (192.168.14.5) melindungi Node.js backend di port internal 3000.

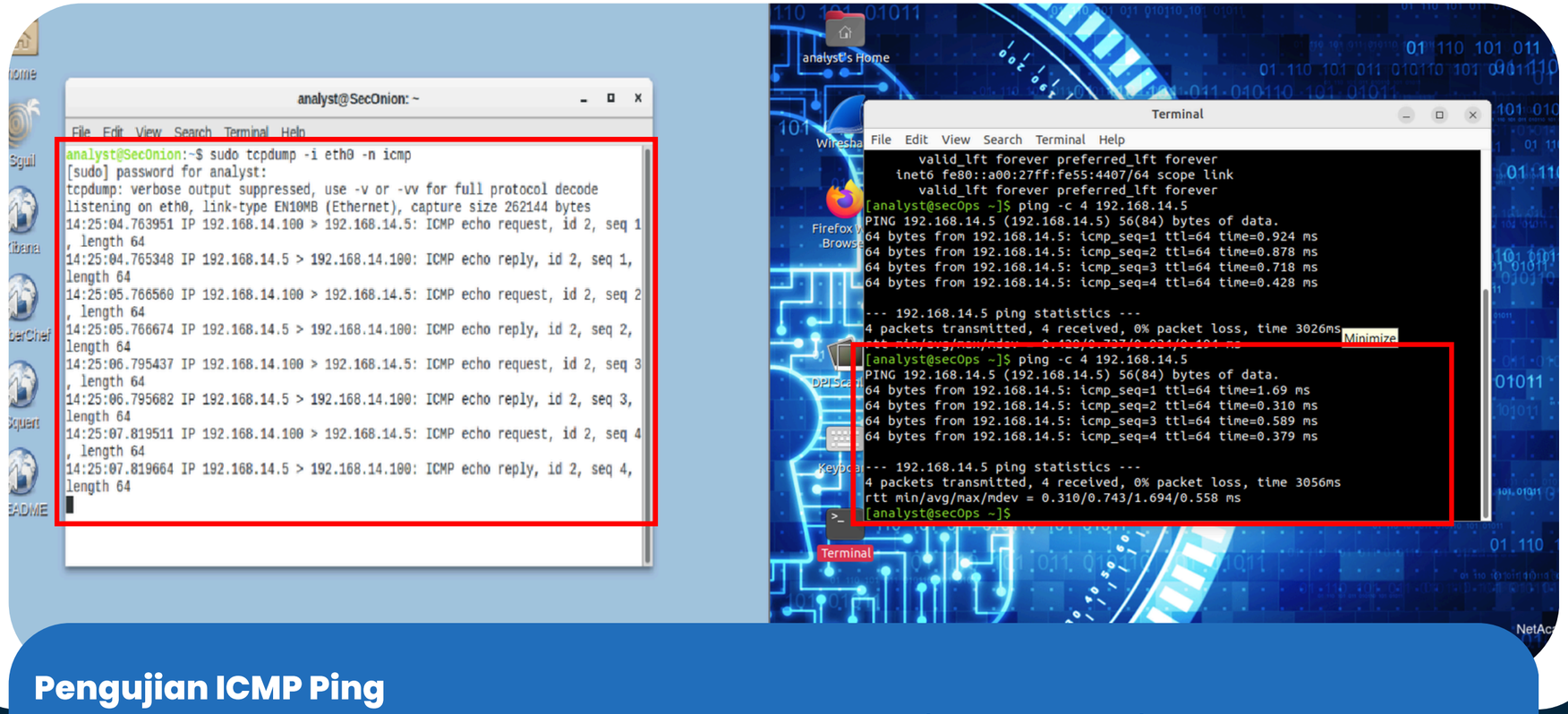
4 Sisi Pengujian & Monitoring
Penyerang ditempatkan pada mesin terpisah (192.168.14.100) agar pengujian celah mencerminkan serangan nyata, sementara Security Onion (192.168.14.50) bertindak sebagai pengawas lalu lintas independen.

Topologi

Attacker , Target dan Monitoring



Baseline Pengujian



Pengujian ICMP Ping

Memastikan koneksi stabil antara Attacker VM (192.168.14.100) dan Target Server (192.168.14.5).

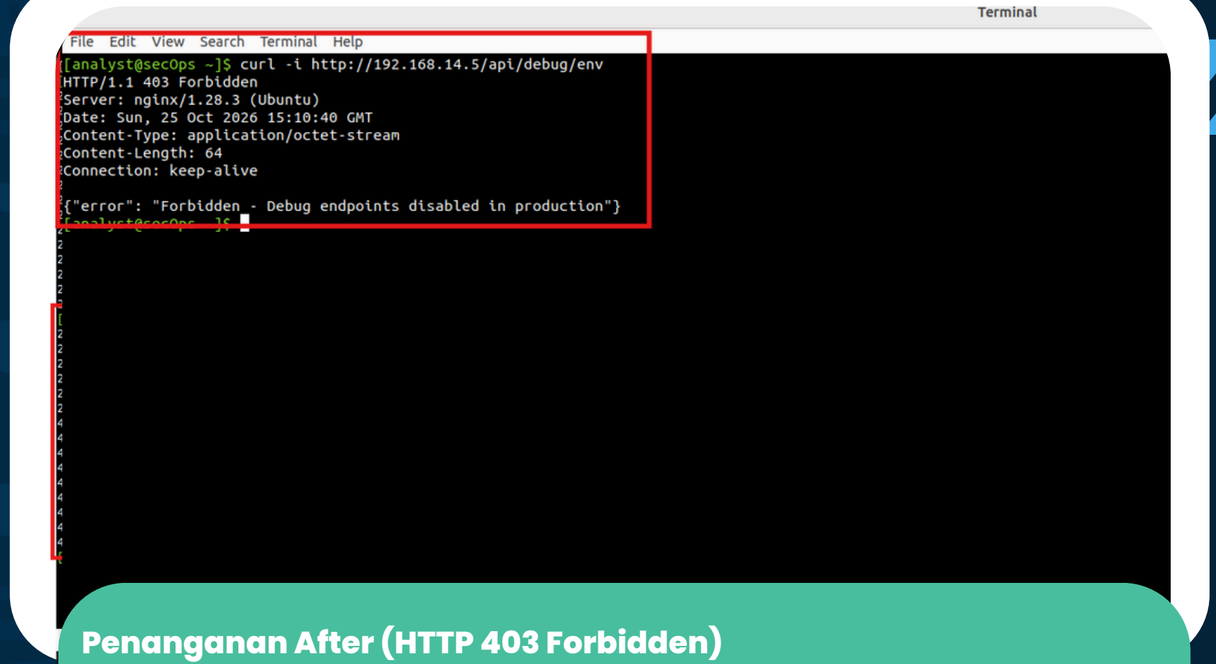
Monitoring Security Onion

Node SIEM (192.168.14.50) merekam lalu lintas paket secara real-time via tcpdump.

Kebocoran Environment & Debug Route

Serangan Before (HTTP 200 OK)

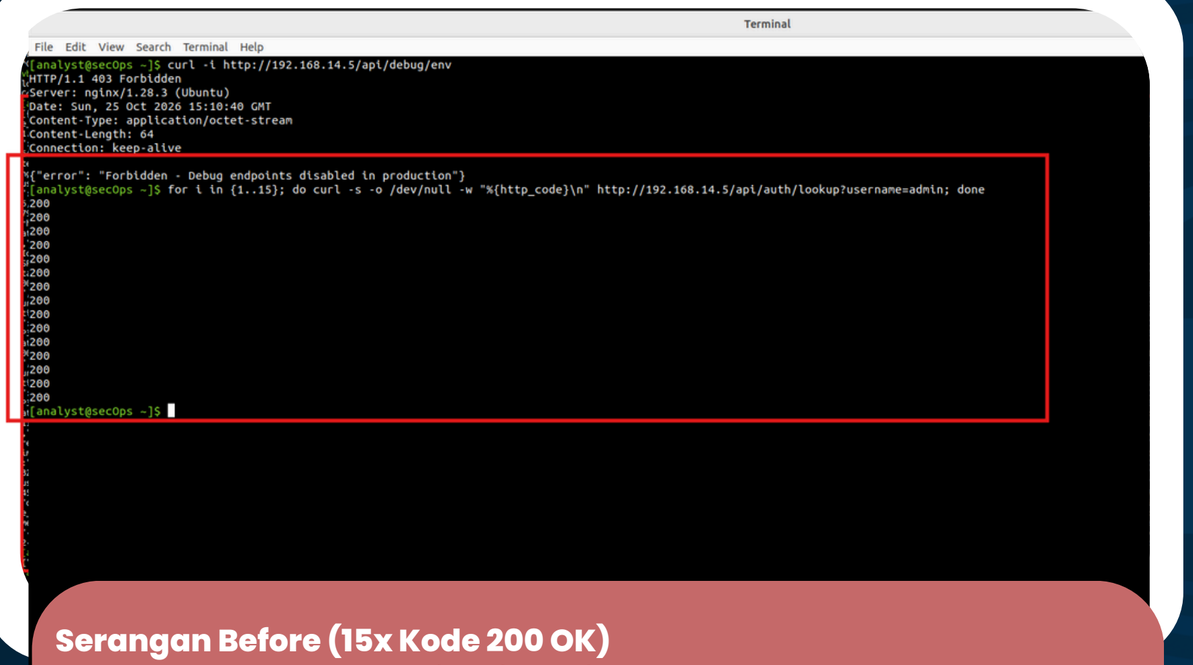
Akses curl ke /api/debug/env mengekspos Firebase private key dan kredensial sistem.



Penanganan After (HTTP 403 Forbidden)

Nginx memblokir total rute debug dengan balasan eksplisit non-production.

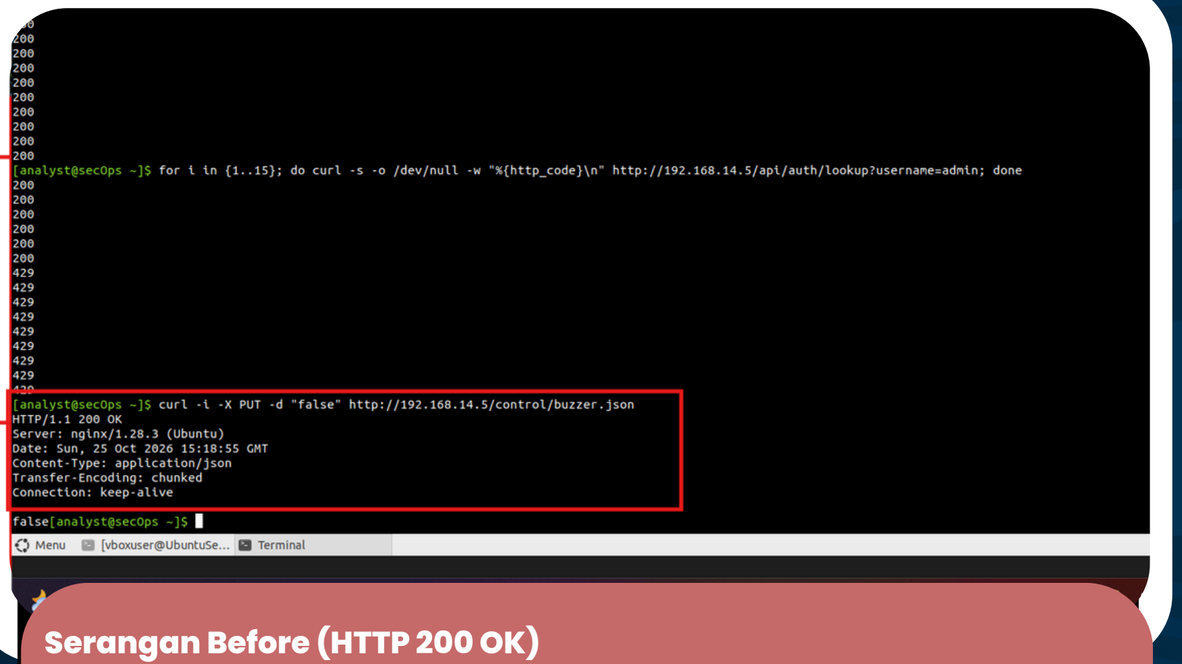
Auth Endpoint Brute-Force & Rate Limiting



Serangan Before (15x Kode 200 OK)
Looping curl 15 kali ke /api/auth/lookup seluruhnya diterima tanpa pembatasan.

Penanganan After (HTTP 429 Too Many Requests)
Penerapan limit_req zona 5r/s memutus request berlebih secara instan.

Buzzer Alarm Tampering & Unauthorized PUT

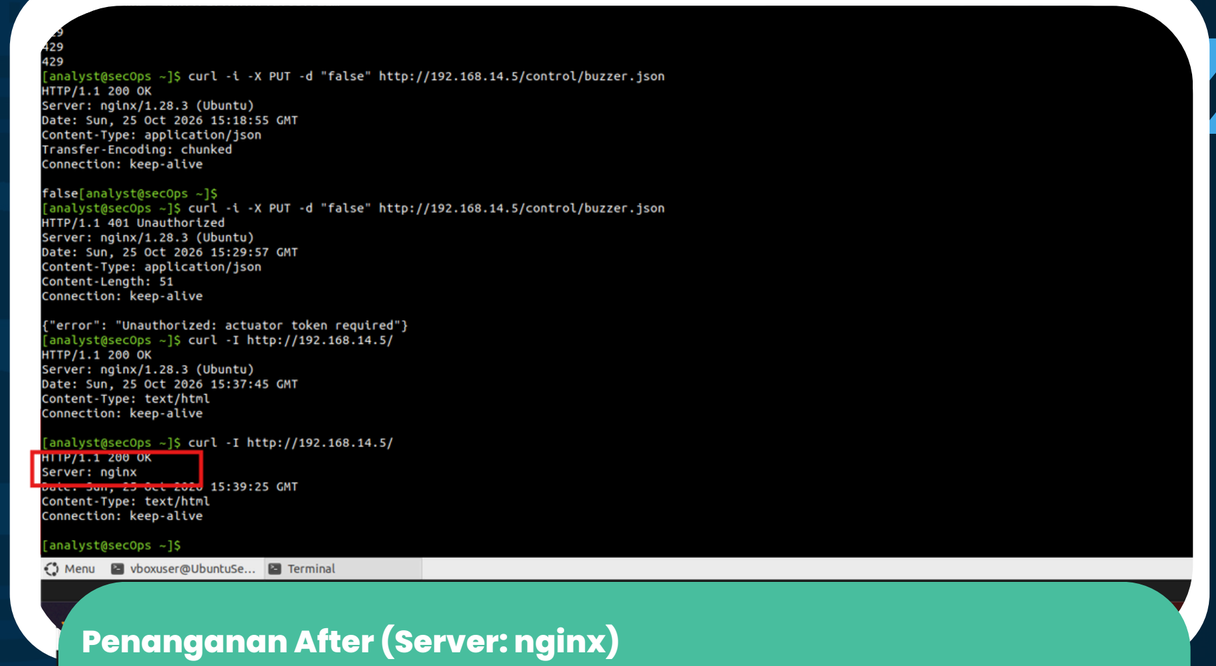


Serangan Before (HTTP 200 OK)
Perintah PUT -d "false" sukses mematikan buzzer darurat reaktor pirolisis.

Penanganan After (HTTP 401 Unauthorized)
Nginx memvalidasi metode request dan menolak manipulasi tanpa token otorisasi.

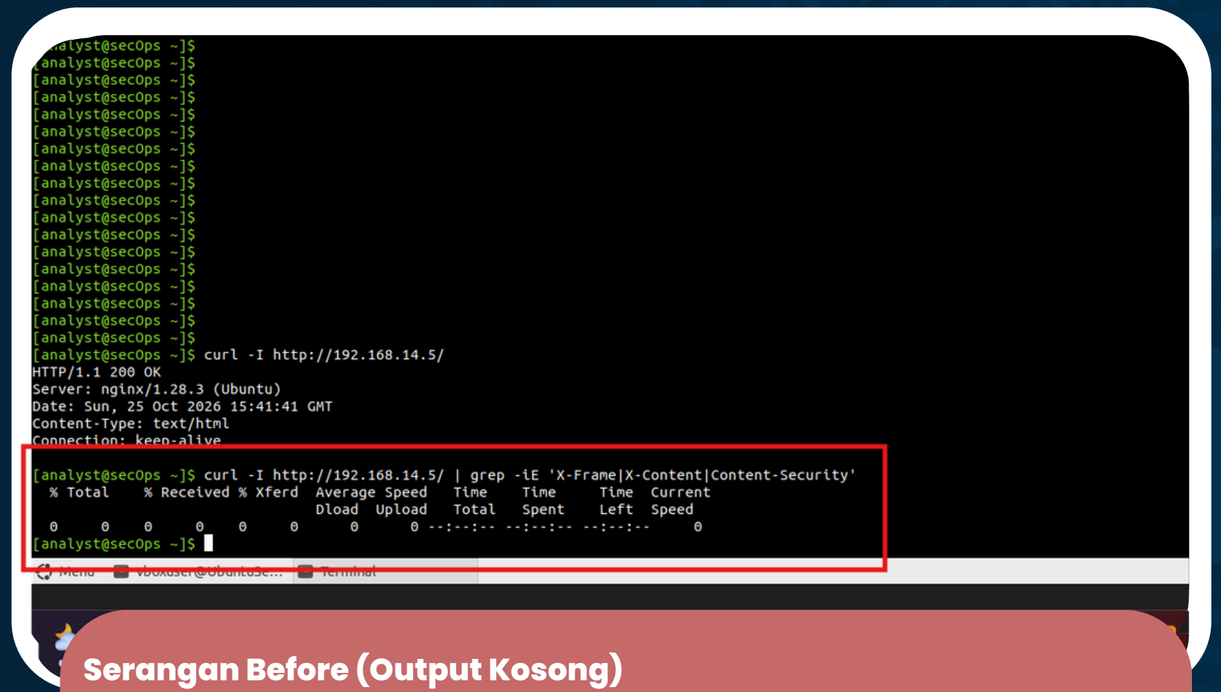
Server Banner Leak & Version Masking

Serangan Before (Bocor Versi Rinci)
Header mencantumkan Server: nginx/1.28.3 (Ubuntu) yang rentan dieksploitasi versi.

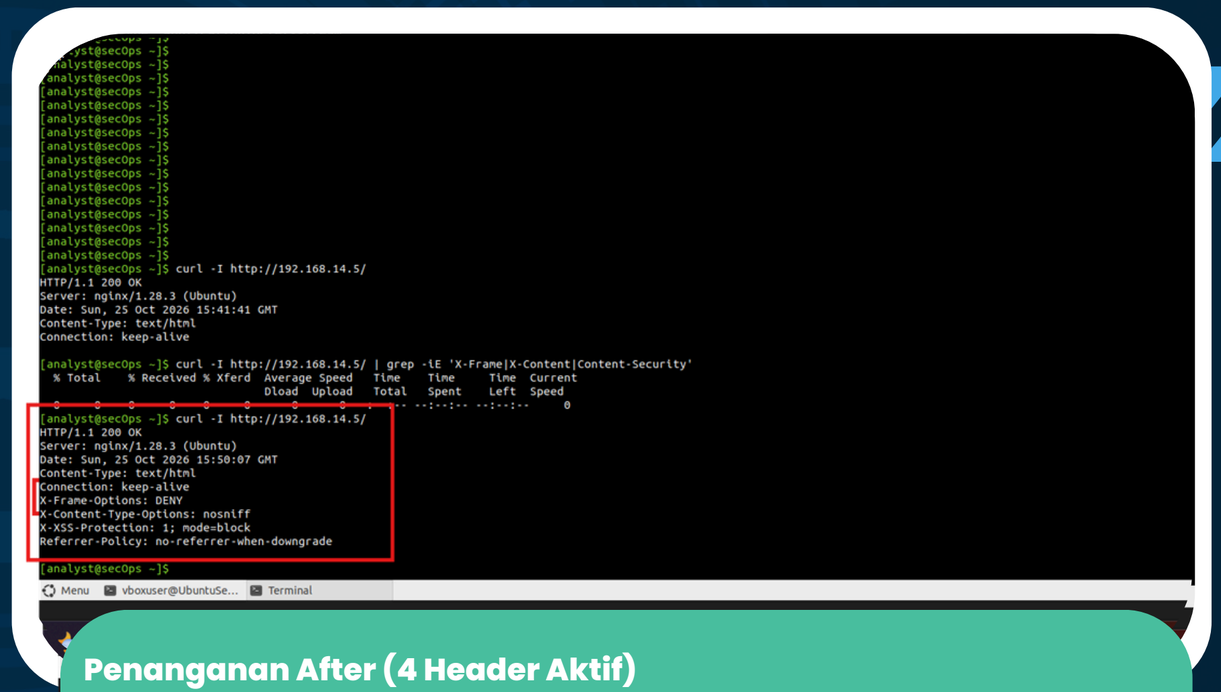


Penanganan After (Server: nginx)
Konfigurasi server_tokens off menyembunyikan rincian versi perangkat lunak.

Missing HTTP Security Headers Enactment



Serangan Before (Output Kosong)
Pemeriksaan grep X-Frame tidak mendeteksi header pengaman browser apa pun.



Penanganan After (4 Header Aktif)
X-Frame-Options, nosniff, XSS-Protection, dan Referrer-Policy terpasang aktif.

Checklist Hardening

No	Kontrol Keamanan	Celah Awal (Before)	Konfigurasi Hardening	Status Akhir (After)	Status

1	**Debug Route Blocking**	Rute `/api/debug/env` terbuka untuk umum dan membocorkan kredensial rahasia (**Firebase private key**) dengan kode status HTTP `200 OK`.	`location ^~ /api/debug/ { return 403; add_header Content-Type application/json; }`
			Menambahkan blok lokasi di Nginx yang memotong akses dengan **return 403** dan header JSON.
				Penyerang langsung ditolak dengan respons eksplisit `HTTP/1.1 403 Forbidden`.
				`HTTP/1.1 403 Forbidden`
				`Content-Type: application/json`
					Verified

2	**Rate Limiting**	Rute otentikasi `/api/auth/lookup` dapat ditembak tanpa **batas**, membuka peluang serangan **brute-force** atau penolakan layanan (DoS).	`limit_req_zone $binary_remote_addr zone=api_limit:10m rate=5r/s;`
			`location /api/auth/ { limit_req zone=api_limit burst=5 nodelay; limit_req_status 429; }`
			Membuat zona memori 10MB, batas 5r/s, serta aturan limit_req.
				Pengujian loop 15 request meloloskan paket awal, lalu sisanya diblokir dengan kode `HTTP/1.1 429 Too Many Requests`.
				`HTTP/1.1 429 Too Many Requests`
				`Retry-After: 1`
					Verified

3	**Actuator Tampering Restriction**	Endpoint status buzzer `/control/buzzer.json` menerima metode `PUT` tanpa verifikasi otentikasi, sehingga alarm bahaya bisa dimatikan sepihak.	`location /control/buzzer.json { if ($request_method != GET) { return 401; } }` Menambahkan validasi metode dan menolak non-GET tanpa token autentikasi.	Pembacaan data (GET) tetap normal, tetapi percobaan manipulasi data lewat PUT langsung digagalkan dengan kode `HTTP/1.1 401 Unauthorized`. `HTTP/1.1 401 Unauthorized`	Verified
4	**Server Banner Masking**	Header respons membocorkan informasi detail versi web server dan sistem operasi (`Server: nginx/1.28.3 (Ubuntu)`).	`server_tokens off;` Mengaktifkan direktif `server_tokens off;` pada konfigurasi Nginx.	Header HTTP disamarkan menjadi format generik **`Server: nginx`**. `Server: nginx`	Verified

5	**HTTP Security Headers**	Server tidak mengirimkan header perlindungan peramban (security headers), rentan terhadap Clickjacking dan MIME sniffing.	`add_header X-Frame-Options "DENY";`
			`add_header X-Content-Type-Options "nosniff";`
			`add_header X-XSS-Protection "1; mode=block";`
			`add_header Referrer-Policy "no-referrer-when-downgrade";`
			Menambahkan 4 header pengaman pada Nginx.
				Seluruh header perlindungan terkonfirmasi muncul pada respnos `curl -I` dari terminal penyerang.
				`X-Frame-Options: DENY`
				`X-Content-Type-Options: nosniff`
				`...`
					Verified

Fokus Pengujian Keamanan: Proteksi kebocoran rute sensitif, pembatasan flooding data telemetri, dan pencegahan sabotase kendali aktuator darurat.

Live Demo

Attack Plan Fase 2

1. Actuator Hijacking
Simulasi bypass otorisasi lanjutan pada kendali katup dan alarm.

2. Telemetry DoS Flood
Uji ketahanan payload jumbo melampaui limitasi 100KB.

3. Auth Enumeration
Analisis log Suricata & Zeek pada Security Onion (192.168.14.50).

Thank You